

Home SOC Lab: Hydra RDP Brute-Force Investigation Report

Analyst: Sree Saran S S | Date: August 5, 2026 | SIEM: Splunk Enterprise 10.4.2 | Incident: RDP credential brute force (detected, credentials recovered, RDP session denied by group policy)

Objective: Simulate a Remote Desktop Protocol (RDP) credential brute-force attack from Kali against a Windows 10 endpoint and detect it in Splunk using Windows Security Event Log telemetry, corroborated with Sysmon network-connection events (EID 3) for protocol-level confirmation.

Background: What is RDP and Why Attack It?

RDP (Remote Desktop Protocol) is Microsoft's proprietary protocol for graphical remote access, listening on TCP port 3389 by default. It is the most common way administrators and users remotely control Windows machines, and by extension one of the most attractive targets for attackers: an internet-exposed RDP port is essentially advertising an interactive login endpoint. Modern Windows deployments protect RDP with Network Level Authentication (NLA), which forces the client to authenticate before a full RDP session is established. NLA raises the bar slightly, but does not stop credential guessing — brute-force tools simply attempt authentication at the NLA layer. Historically, RDP has been the initial-access vector behind ransomware families such as SamSam, Dharma, and BlueKeep-based intrusions. In this exercise, RDP on the Windows victim was targeted with a small dictionary attack using Hydra to test whether Splunk would (a) detect the flood of failed logons, and (b) allow the analyst to differentiate RDP from other credential-guessing attacks such as SMB.

1. Lab Architecture

Same three-VM SOC lab used for the prior Nmap and Hydra SMB investigations. All VMs communicate over a Bridged Adapter on the local network (192.168.29.x).

VM	Role	IP	Purpose
Splunk Enterprise 10.4.2 (Ubuntu 22.04)	SIEM / Indexer	192.168.29.97 (static)	Ingest, index, and search Windows security telemetry and Sysmon events
Windows 10 Pro (DESKTOP-9M1T24R)	Victim endpoint	192.168.29.226	Target machine; RDP (3389) exposed; testvictim account brute-forced
Kali Linux 2026.2	Attacker	192.168.29.163	Runs Hydra with a small credential wordlist against Windows RDP

2. Preparation Steps

Target Account and RDP Access

The testvictim local account created for the Hydra SMB exercise was reused. RDP was already enabled on the Windows VM (default lab configuration). Notably, testvictim was left as a standard local user and was NOT added to the Remote Desktop Users group. This detail becomes important in the Key Observations.

Wordlists Reused from SMB Exercise

The same two wordlists from the Hydra SMB attack were reused on Kali so the two investigations could be compared on identical inputs. The password list includes Password123 at position 10 as the known-valid credential. Small lists were used deliberately to keep the attack duration short and the log volume readable.

[INSERT SCREENSHOT: passwords.txt on Kali - 10 candidate passwords, Password123 at position 10]

Figure 1: passwords.txt on Kali - 10 candidate passwords, including the correct one.

[INSERT SCREENSHOT: users.txt on Kali - 5 candidate usernames including testvictim]

Figure 2: users.txt on Kali - 5 candidate usernames, including testvictim.

3. Attack Execution

Attack Command

```
hydra -L users.txt -P passwords.txt -t 1 rdp://192.168.29.226
```

Flag Breakdown

- L users.txt: try every username from the file

- -P passwords.txt: try every password from the file
- -t 1: single-threaded (RDP session setup is stateful; parallel attempts destabilise the session and are commonly dropped by NLA)
- rdp://192.168.29.226: target Windows RDP service on the victim IP (port 3389)

Attacker-side Result

Hydra completed 50 combinations in approximately 1 minute 40 seconds — significantly slower than the equivalent SMB attack because RDP session setup is more expensive per attempt. Hydra's own summary line reported "0 valid password found", but the tool also emitted a critical intermediate message:

```
[3389][rdp] account on 192.168.29.226 might be valid but account not active for remote desktop:
login: testvictim password: Password123, continuing attacking the account.
```

This is Hydra flagging that credentials authenticated correctly at the NLA layer, but Windows then refused the RDP session because the account is not a member of the Remote Desktop Users group. From a purist tool-output perspective this is "0 valid passwords" (no session), but from an analyst perspective this is a fully successful credential compromise — the password is confirmed correct. Windows' authorisation policy was the second layer of defence that prevented remote-desktop access. The tool itself flags its RDP module as experimental ("the rdp module is experimental. Please test, report - and if possible, fix.") which is a useful caveat for any real-world use.

[INSERT SCREENSHOT: Hydra RDP output showing 'might be valid but account not active for remote desktop: login: testvictim password: Password123']

Figure 3: Hydra output from Kali. Credentials confirmed valid for testvictim / Password123, but RDP session denied because the account is not in the Remote Desktop Users group. Hydra's summary reports "0 valid passwords found" because it counts a valid password only if a session is established.

4. Detection in Splunk

Preflight and Data-Source Baseline

Before hunting, a source-baseline query was run to confirm Sysmon and Windows Security events were both flowing from the victim endpoint. This step also revealed that the Sysmon sourcetype in this lab is XmlWinEventLog:Microsoft-Windows-Sysmon/Operational (XML-rendered) rather than the more common WinEventLog:Microsoft-Windows-Sysmon/Operational — an environment-specific detail that affects every Sysmon query in this report.

```
host=DESKTOP-9M1T24R sourcetype=*sysmon* earliest=-60m | stats count by sourcetype
```

Initial Discovery Search

The hunt began by looking for any failed logon activity on the victim during the attack window, without assuming a protocol:

```
host=DESKTOP-9M1T24R sourcetype="WinEventLog:Security" EventCode=4625 earliest=-30m
```

This returned 49 events tightly clustered in a two-minute window — the classic burst signature of an automated tool rather than organic user typing errors.

[INSERT SCREENSHOT: Splunk showing 49 EventCode=4625 events in the attack window with a burst in the timeline histogram]

Figure 4: 49 failed logon (EventCode=4625) events recorded during the RDP brute-force window - the classic 'flood' signature.

Attribution: Attacker IP, Logon Type, and Targeted Accounts

A single stats query answers three attribution questions at once: which IP is attacking, what type of logon is being attempted, and which accounts are being targeted:

```
host=DESKTOP-9M1T24R sourcetype="WinEventLog:Security" EventCode=4625 earliest=-30m | stats
count by Source_Network_Address, Logon_Type, Account_Name | where Account_Name!=" - "
```

All 49 events traced back to 192.168.29.163 (Kali). Attempts were distributed across all five usernames in the wordlist (administrator, admin, ssss, guest — 10 each) with testvictim showing 9 failures. The missing tenth attempt for testvictim corresponds to the credential pair that authenticated successfully at the NLA layer (Password123) and therefore did not generate a 4625. Every event registered as Logon Type 3 (Network) rather than Logon Type 10 (RemoteInteractive) — see Key Observations for why this matters.

[INSERT SCREENSHOT: Splunk stats table: 192.168.29.163 → 5 accounts, Logon Type 3, counts 10/10/10/10/9 = 49 total]

Figure 5: Attribution table - all 49 failures originate from 192.168.29.163 (Kali), all Logon Type 3, distributed across the five usernames in the Hydra wordlist.

Protocol Confirmation via Sysmon EID 3

Because Hydra's RDP module authenticates via NLA and produces Logon Type 3 events (indistinguishable from SMB at the Security-log layer), Windows Security logs alone are not sufficient to confirm the attack was RDP. Sysmon EID 3 (network connections) was queried to correlate the failed logons with actual traffic on port 3389:

```
host=DESKTOP-9M1T24R sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational" earliest=-2h | rex "<EventID>(?(eid>\d+)</EventID>" | where eid=3 | rex "Name='SourceIp'>(?(src_ip>[^\>+])<" | rex "Name='DestinationIp'>(?(dst_ip>[^\>+])<" | rex "Name='DestinationPort'>(?(dst_port>[^\>+])<" | stats count by src_ip, dst_ip, dst_port
```

Fields inside the raw Sysmon XML are not auto-extracted by Splunk under the XmlWinEventLog sourcetype, so inline rex commands were used to pull SourceIp, DestinationIp, and DestinationPort from the <Data Name='...'> XML tags. Plain-English breakdown of the query: pull every Sysmon event in the last two hours, extract the EventID number, keep only EID 3 (network connections), extract the three IP/port fields from each event's XML, then group and count.

The query returned 51 network connections from 192.168.29.163 → 192.168.29.226 on port 3389 in the attack window — protocol-level confirmation that the failed 4625 events were the result of RDP traffic, not SMB. The three other rows in the output (192.168.29.226 → Microsoft-owned IPs on 443) are ordinary Windows Update / telemetry traffic and were disregarded.

[INSERT SCREENSHOT: Sysmon EID 3 stats table showing 51 connections from 192.168.29.163 to 192.168.29.226 on port 3389]

Figure 6: Sysmon EID 3 confirms 51 network connections from 192.168.29.163 to 192.168.29.226 on port 3389 - protocol-level proof that the failed logons were caused by RDP traffic.

Individual Evidence Event (4625) - Full Detail

A single 4625 event targeting testvictim was expanded to inspect the raw fields. Every field needed for a formal incident write-up is captured here:

[INSERT SCREENSHOT: Expanded 4625 event: LogonType 3, Account testvictim, Sub Status 0xC000006A, Workstation kali, Source 192.168.29.163]

Figure 7: Expanded failed logon event. Logon Type 3 (network - NLA), target account testvictim, failure reason 'Unknown user name or bad password', Sub Status 0xC000006A (wrong password), Workstation Name kali, Source Network Address 192.168.29.163.

Field	Value	Analyst Interpretation
EventCode	4625	Failed logon event
Logon Type	3	Network logon - Hydra's RDP module uses NLA credential validation, which Windows logs as Network, not RemoteInteractive (Type 10)
Account For Which Logon Failed	testvictim	The targeted local account on Windows
Account Domain	(blank)	Local (non-domain) authentication
Failure Reason	Unknown user name or bad password	Windows will not disambiguate - typical credential guessing signal
Status	0xC000006D	STATUS_LOGON_FAILURE
Sub Status	0xC000006A	STATUS_WRONG_PASSWORD - user exists, password wrong
Workstation Name	kali	Attacker announced its own hostname in the session - OpSec failure
Source Network Address	192.168.29.163	Attacker IP - matches Kali VM
Source Port	0	Not populated for NLA / pre-session authentication
Authentication Package	NTLM (NtLmSsp)	Legacy Windows challenge/response auth over the NLA channel

5. Investigation Analysis

The 6-Question Framework Applied

Question	Answer
WHO (Source)	Attacker at 192.168.29.163. Workstation Name announced in the failed logon events as "kali", indicating a Kali Linux origin. Behaviour is consistent with an automated RDP brute-force tool such as Hydra, Ncrack, or Crowbar. Ground truth in this exercise confirms the tool was Hydra v9.7 (RDP module - flagged as experimental by the maintainer).
WHAT (Activity)	RDP credential brute force. 49 failed logon events (EventCode 4625) and 51 network connections to TCP/3389 (Sysmon EID 3) captured within a two-minute window. Credentials for testvictim / Password123 were confirmed valid at the NLA layer, but the RDP session was refused by Windows because the account is not in the Remote Desktop Users group.
WHEN (Timestamp)	August 5, 2026 at 12:43:46 IST (first failed 4625 event). Attack duration approximately 1 minute 40 seconds end-to-end.
WHERE (Target)	Windows 10 endpoint DESKTOP-9M1T24R (192.168.29.226), RDP port 3389. Local account testvictim in WORKGROUP.
HOW (Method)	Hydra dictionary attack driving the RDP module. 5-username x 10-password wordlist (50 combinations). Logon Type 3 (network) at the Security-log layer; Sysmon EID 3 confirms the underlying transport was TCP/3389. Authentication package NTLM (NtLmSsp) over the NLA channel.
WHY IT MATTERS	The attack was partially successful: the attacker recovered a valid credential (testvictim / Password123) but was blocked from interactive access by RDP group membership policy. This is a textbook demonstration of defence-in-depth — a weak password alone was not enough to compromise the endpoint because a second control (Remote Desktop Users group membership) held. Nevertheless, the credential itself is now confirmed compromised and could be used against other services on the same host (SMB was already compromised via the same credential in the prior exercise), or laterally against other hosts if the password is reused. Credential-based initial access remains the #1 real-world intrusion vector.

MITRE ATT&CK Mapping

Technique	Tactic	Description
T1110	Credential Access	Brute Force (parent technique)
T1110.001	Credential Access	Password Guessing - trying multiple passwords against one or more accounts
T1021.001	Lateral Movement	Remote Services: Remote Desktop Protocol - target protocol used for authentication
T1078.003	Persistence / Initial Access	Valid Accounts (Local) - the compromised account is a local Windows user

Key Observations

- **Logon Type does not identify RDP on its own.** Every failed 4625 event registered as Logon Type 3 (Network), not Logon Type 10 (RemoteInteractive) as textbooks often suggest for RDP. This is because Hydra's RDP module authenticates via NLA credential validation without ever establishing a full remote-desktop session. A real interactive RDP login (via mstsc.exe) would produce Type 10; Hydra produces Type 3. This means a detection rule that filters on Logon_Type=10 would completely miss this attack. The correct approach is to use Windows Security logs to detect the failed authentication and correlate with Sysmon EID 3 (or firewall logs) to confirm the transport port.
- **Sub Status 0xC000006A leaks account existence.** Every failed event carried Sub Status 0xC000006A ("user exists, wrong password") rather than 0xC0000064 ("user does not exist"). This tells the analyst that every account in the Hydra wordlist — administrator, admin, ssss, testvictim, guest — is a real local account on this host. In a real investigation this is useful attacker-intelligence: the attacker had already validated the username list before running the password portion, or the account discovery was accidental. Either way, defenders can now inventory valid accounts by observing sub-status codes.

- **Event-count discrepancy (49 4625 vs 51 Sysmon EID 3 vs 50 Hydra attempts).** Hydra reports 50 combinations. Windows logged 49 failed authentications. Sysmon logged 51 network connections. Likely explanations: (1) the successful NLA authentication for testvictim / Password123 did not generate a 4625 (auth succeeded, but authorisation to RDP failed and is logged separately — accounting for the 50 → 49 gap), and (2) Sysmon captures TCP-layer connections including handshakes and retries that don't correspond 1:1 with authentication attempts (accounting for the 49 → 51 excess). This kind of counting drift is exactly where evasion techniques hide in real incidents and is worth documenting.
- **Defence in depth actually worked.** The password was correct but the attacker still could not RDP in, because testvictim was not a member of the Remote Desktop Users group. This is a rare live example of a second control catching a failure of the first. Any production RDP-exposed host should enforce this exact configuration — never grant remote-desktop rights to standard users by default.
- **Attacker OpSec was poor.** Kali announced its own hostname ("kali") in the Workstation Name field of every failed logon. In a real attack, an adversary would spoof this. Its presence in the logs is a free attribution win.
- **Hydra's RDP module is officially experimental.** The tool prints a warning on every run: "the rdp module is experimental. Please test, report - and if possible, fix." Its "0 valid passwords found" summary is misleading when the account exists but is not RDP-authorised, and any red-team engagement using Hydra against RDP should cross-verify with Ncrack or Crowbar.

6. Recommended Remediations

Immediate (Containment)

1. Quarantine the affected endpoint DESKTOP-9M1T24R from the network to prevent lateral movement.
2. Force password reset on testvictim - the credential is now confirmed compromised even though RDP access was denied. The same password is very likely valid over SMB, WinRM, and any other authenticated service on this host.
3. Force password reset on any other local account that may share the same weak password pattern.
4. Block the attacker source IP 192.168.29.163 at the perimeter firewall.

Investigation (Follow-up)

5. Review all 4624 (successful logon) events from 192.168.29.163 across the whole environment to confirm whether the attacker succeeded elsewhere.
6. Trace all file access, process creations (Sysmon EID 1), and network activity (Sysmon EID 3) tied to any testvictim session after the 12:43 IST timestamp.
7. Check for new local account creation (Event ID 4720) and privilege changes (4728 - user added to a privileged group, 4732 - user added to a local group) after the compromise time. Specifically watch for addition of testvictim to the Remote Desktop Users group as a persistence move.
8. Audit the Remote Desktop Users group membership across all endpoints to identify any accounts that should not be there.

Long-Term (Prevention)

9. Build a Splunk correlation alert: more than 10 failed logon (EventCode=4625) events from a single Source_Network_Address within 60 seconds should trigger a real-time notable event. This rule catches both SMB and RDP brute force with one signature.
10. Enforce Windows account lockout policy (e.g. 5 failed attempts = 30-minute lockout) to prevent Hydra-style attacks from completing.
11. Restrict RDP access at the network layer - RDP should never be reachable from arbitrary source IPs. Use a jump host, VPN, or Windows Firewall scoping to trusted management subnets only.
12. Enforce Network Level Authentication (NLA) - already active in this lab; ensure it is never disabled for compatibility reasons.
13. Consider RDP-specific mitigations: change the default port from 3389, enforce certificate-based authentication, or deploy a Remote Desktop Gateway with MFA.
14. Enforce a strong password policy that would defeat a 10-word dictionary trivially (12+ chars, complexity, block common patterns like Season+Year).

7. Skills Demonstrated

- Executed a real credential brute-force attack (Hydra) against a lab endpoint over RDP.
- Investigated the resulting security events in Splunk without hard-coding an Event ID up-front, using a progressive-narrowing hunt methodology.
- Wrote multi-stage SPL queries with stats, where, and inline rex extractions to work around a raw-XML sourcetype (XmlWinEventLog:Microsoft-Windows-Sysmon/Operational).
- Correlated two data sources - Windows Security 4625 events and Sysmon EID 3 network connections - to confirm the attack protocol was RDP, not SMB, despite both producing Logon Type 3 at the Security-log layer.
- Correctly interpreted Windows Event IDs 4624/4625, Logon Types 3 vs 10, Failure Reasons, and NTLM sub-status codes (0xC000006A, 0xC000006D).
- Diagnosed a real-world Hydra RDP behavior: the tool's "0 valid passwords" summary is misleading when a credential is valid but the account is not RDP-authorized.
- Identified defence-in-depth working live: password compromise + RDP group restriction = attacker denied session access.
- Mapped the observed activity to MITRE ATT&CK techniques T1110.001, T1021.001, and T1078.003.
- Produced a structured incident report following the 6-Question analyst framework.

Report prepared by Sree Saran S S as part of SOC Analyst (L1) training and portfolio development.